

LAMPIRAN PENGUJIAN BLACKBOX

Sistem Sellica

Sistem Evaluasi Individu dan Catatan Aktivitas

Backend + Frontend Testing

Komponen	Total Tes	Pass	Fail	Warn	Skor
Backend API	71	64	7	0	90%
Frontend Security	24	4	11	4	17%
Frontend Auth Flow	13	5	3	5	38%
Frontend Navigation	31	27	4	0	87%
Frontend Responsive+A11y	18	8	6	4	44%
Frontend Form Validation	15	10	1	4	67%
Frontend Error Handling	11	4	3	4	36%
TOTAL	183	122	35	21	67%

Tanggal: 6 Juli 2026
Auditor: Hikari (Multi-Agent System)

BAB 1: Ringkasan Pengujian Backend

Pengujian blackbox backend Sellica menggunakan Postman Collection dan Newman CLI. Target: Go backend API di port 8080.

Metrik	Nilai
Total Endpoint	21 (AI deprecated) + existing
Total Test Case	71
Pass	64 (90%)
Fail	7 (rate limiter + format assertions)
Newman Runs	8 iterasi
Security Findings	22 (3 Critical, 6 High, 8 Medium, 5 Low)
Fixes Applied	12 across 3 rounds
Deprecated Endpoints	21 (410 Gone)

BAB 2: Temuan Keamanan Backend

ID	Severity	Temuan	Lokasi	Status
C1	CRITICAL	Auth bypass - migration placeholder accepts any password	auth/service.go	FIXED
C2	CRITICAL	CORS allows all origins in dev middleware	routes/routes.go	FIXED
C3	CRITICAL	Rate limiter cosmetic (headers only, no blocking)	middleware/auth.go	FIXED
H1	HIGH	Service role key hardcoded in .env	config/config.go	MITIGATED
H2	HIGH	Debug endpoint exposes internal state	routes/routes.go	FIXED
H3	HIGH	AI endpoints return training data without auth	concurrent.go	DEPRECATED
H4	HIGH	Input validation missing on bulk operations	handlers	FIXED
H5	HIGH	Error messages leak stack traces	middleware	FIXED
H6	HIGH	WebSocket connections without auth	websocket	DOCUMENTED
M1	MEDIUM	Cache clear endpoint unprotected	routes.go	FIXED
M2	MEDIUM	Health check exposes Supabase status	routes.go	NOTED

BAB 3: Temuan Keamanan Frontend

ID	Severity	Temuan	Status
F1	CRITICAL	Semua protected routes bisa diakses tanpa autentikasi	PARTIAL FIX
F2	CRITICAL	Tidak ada security headers (CSP, X-Frame-Options, HSTS)	FIXED
F3	HIGH	Auth token disimpan di localStorage (XSS risk)	DOCUMENTED
F4	HIGH	Tidak ada library sanitization (DOMPurify)	DOCUMENTED
F5	HIGH	Go backend unreachable dari frontend PC	FIXED (Tailscale)
F6	MEDIUM	Register Step 1 tanpa validasi input	DOCUMENTED
F7	MEDIUM	Button click handler tidak trigger form submit	DOCUMENTED
F8	MEDIUM	Password reset belum diimplementasi	DOCUMENTED
F9	LOW	X-Powered-By header ter-expose	FIXED (config)

BAB 4: Hasil Pengujian Navigasi Frontend

Pengujian 31 route Sellica. 27 route berhasil dimuat, 4 route timeout.

Route	Status	Ukuran	Keterangan
/	200 OK	60 KB	Homepage
/login	200 OK	29 KB	Form login
/register	200 OK	29 KB	Multi-step register
/forgot-password	200 OK	38 KB	Reset password
/privacy	200 OK	41 KB	Kebijakan privasi
/terms	200 OK	43 KB	Syarat ketentuan
/cookies	200 OK	41 KB	Kebijakan cookie
/silpana	200 OK	59 KB	Silpana publik
/error	200 OK	33 KB	Halaman error
/dashboard	200 OK	36 KB	TANPA AUTH!
/admin	200 OK	38 KB	TANPA AUTH!
/silpana-admin	200 OK	38 KB	TANPA AUTH!
/profile	200 OK	38 KB	TANPA AUTH!
/monitoring	200 OK	38 KB	TANPA AUTH!
/data-rekam	200 OK	38 KB	TANPA AUTH!
/aktivitas-user	200 OK	36 KB	TANPA AUTH!
/aktivitas-user/aktivitas-siak	200 OK	35 MB!	ABNORMAL SIZE
/maintenance	000	0	Timeout
/silpana-admin/analytics	000	0	Timeout
/aktivitas-user/pengaduan-bulanan	000	0	Timeout
/nonexistent-404	000	0	No custom 404

BAB 5: Hasil Pengujian Autentikasi Frontend

Test Case	Expected	Actual	Status
Login - form kosong	Button disabled	Button disabled	PASS
Login - email salah format	Validasi error	Please enter valid email	PASS
Login - password salah	Error message	Invalid email or password	PASS
Login - button click	Form submit	Tidak trigger (butuh Enter)	WARN
Register - Step 1 kosong	Validasi error	Tidak ada validasi	FAIL
Register - email salah	Validasi error	Please enter valid email	PASS
Register - password lemah	Strength error	Validasi ditampilkan	PASS
Forgot - form kosong	Validasi	Browser native validation	PASS
Protected - /dashboard	Redirect /login	Load tanpa auth	FAIL
Protected - /admin	Redirect /login	Load tanpa auth	FAIL
XSS - reflected	Tidak reflected	Tidak reflected (escaped)	PASS
SQL Injection	Tidak error	Tidak error (parameterized)	PASS

BAB 6: Perbaikan yang Diterapkan

#	Perbaikan	File	Status
1	Security headers (X-Content-Type, X-Frame, XSS, Referrer, Permissions)	middleware.ts	DONE
2	Auth cookie detection pada protected routes	middleware.ts	DONE
3	X-Auth-Verified header untuk client-side check	middleware.ts	DONE
4	Auth bypass fix (bcrypt verification)	auth/service.go	DONE
5	CORS production middleware	routes/routes.go	DONE
6	Rate limiter (real blocking)	middleware/auth.go	DONE
7	21 AI endpoints deprecated (410)	concurrent.go	DONE
8	Go backend connectivity via Tailscale	frontend .env	DONE
9	poweredByHeader: false	next.config.mjs	DONE
10	Supabase admin client disabled	admin/page.tsx	DONE

BAB 7: Lingkungan Pengujian

Komponen	Versi/Detail
Backend	Go 1.23 + Gin framework
Frontend	Next.js 15.4.6 + React + Supabase
Database	Supabase (PostgreSQL)
Auth	Supabase Auth + Go JWT
API Testing	Postman Collection v2.1 + Newman
Frontend Testing	Hermes Browser Automation (Puppeteer)
VPS	Ubuntu 20.04, 3.8GB RAM, 59GB disk
PC Server	Windows Server 2016, 16GB RAM
Network	Tailscale VPN (100.87.204.98 ↔ 100.104.41.34)
Test User	newman_test_1783320185@sellica.com
Tanggal	6 Juli 2026